

5	LIDERAZGO		MOTIVO	ACCION CORRECTIVA
5.1	LIDERAZGO Y COMRPOMISO			
1	¿Se han establecido objetivos de la Seguridad de la Información acordes con los objetivos del negocio?	CUMPLE PARCIALMENTE	se tiene objetivos pero no cumple los estandares medios de seguridad de la informacion	Establecer objetivos (específicos, medibles, alcanzables, relevantes y temporales) alineados con el plan estratégico del negocio.
2	¿La dirección provee de los recursos materiales y humanos necesarios para el cumplimiento de los objetivos del SGSI?	CUMPLE PARCIALMENTE	-los recursos son basicos en hambito fisico ya que cuentan con equipos viejos sin actualizaciones, en recursos humanos baja ya que no hay un equipo especifico que cumpla esta funcion	Evaluar las necesidades del SGSI y documentar la asignación de recursos humanos, tecnológicos y financieros.
3	¿La dirección revisa directamente la eficacia del SGSI para garantizar que se cumplen los objetivos del SGSI	NO CUMPLE	la prioridad de la direccion es nula en hambito SGSI, dejando a la deriva esta area. en donde no cuenta con equipo humano para la revicion y exposision de fallas	Establecer una agenda periódica de revisión por la dirección, documentar actas y decisiones tomadas
5.2	POLITICA DE LA SEGURIDAD DE LA INFORMACION			
1	¿Se ha definido una Política de la Seguridad de la Información?	CUMPLE	cuenta con una politica de seguridad	estar en un constante actualizacion de las politicas dependiendo de las necesidades de la seguridad de datos
2	¿Se ha establecido un marco que permita el establecimiento de objetivos?	CUMPLE PARCIALMENTE	cuenta con objetivos pero no esta documentada la informacion debido a esto no se pueden generar estaditicas o evaluar el progreso del objetivo	Desarrollar e implementar un marco documentado que conecte la política con metas específicas de seguridad

3	¿Se ha comunicado la política de la Seguridad de la información a las partes interesadas y a toda la empresa?	CUMPLE	ese evidencia que cumplen con comucar sobres las politicas de seguridad.	recomendamos que las politicas esten accesibles a las personas involugradas. que tengas una comunicacion activacon el equipo de trabajo. palnificar estrategias continuas para actuliazar las politicas mediante evolucion de la empresa. documentar too tipode cambio osugerencias o eliminacion
4	¿Se mantiene información documentada de la política del SGSI y de sus objetivos?	CUMPLE	si se mantiene la informacion documentada	mejoraria la documentacion de los objetivos ya que con estos podemos realizar analisis medibles, clasificarlos por su grado
5.3	ROLES Y RESPONSABILIDADES			
1	¿Se han asignado las responsabilidades y autoridades sobre la Seguridad de la Información?	CUMPLE PARCIALMENTE	se asiganron pero no se tiene bien claro las responsabilidades	definir laramente cada rol y responsabilidades. establecer quien o quienes toman las deciciones finales. documentar y comunicrresponsabilidades
2	¿Se han comunicado convenientemente las responsabilidades y autoridades para la Seguridad de la Información?	CUMPLE PARCIALMENTE	existe una comunicacion pero no esconstante dejando a la deriba en siertos aspectos ante dificultades y toma de decinones importantes	
6	PLANIFICACION			
6.1	TRATAMIENTO Y RIESGOS DE OPORTUNIDADES			
1	¿El plan para abordar riesgos y oportunidades considera las expectativas de las partes interesadas en relación a la Seguridad de la Información?	NO CUMPLE	se cuenta con un plan de riesgos pero no se actualizado segun las necesidades de hoy en la proteccion de riesgos sobre la informacion obtenida, el cual los datos de los clientes tienen un cierta expocicion, en pocas palabras no se esta teniendo encuesta la seguridad de los clientes	Realizar un análisis de partes interesadas y su relación con la seguridad de la información; actualizar el análisis de riesgos.

2	¿Se identifican y analizan los riesgos mediante un método de evaluación y aceptación de riesgos?	CUMPLE PARCIALMENTE	cuentan con un metodo pero general,no detallado segun las areas entendiendo las areas como identificacion de riesgos, evaluacion de dichos riesgos, decir que procesos se llevan a cabo, sin esto claro no cuentan con un respaldo de de un analisis normado para ver el grado de los riesgos, sin tener esto nos lleva a no tener niveles de riesgos por consecuencia no hay pidades claras.	-la identificacion clara de losposibles riesgos, implementacion de metodologias actualizadas de evaluacion de riesgos, capacitacion del equipo humano en certificaciones de dichas metodologias. definiicon de criterios para la evaluacion como por ejemplo cual es el niel de riesgo, plan de accion determinado para cada nivel, una clara documnetacion de todo plan de reisos con sus analisis, responsables a cargo, las acciones tomadas
3	¿Se ha definido un proceso de tratamiento de riesgos?	CUMPLE PARCIALMENTE	-se cuenta con uno pero no esta actializado segun las exigencias de hoy. no se tiene claro los procesos, no hay nada formal como documentacion, no se tiene un catastro de riesgos o niveles	la implementacion de porcesos normados de tratamientos d riesgos, utilizacion de recursos como planillas o matriz de riesgos ya definidos para luego realizar la comparacion de evolucion de los objetivos para su analisis, una adecuada documentacion que incluya las acciones tomadasque responsables la jecutaron, que resultados se obtuvieron, en pocas palabras un plan normado con una revicion constante del personal definido
4	¿Se han establecido criterios para elaborar una declaración de aplicabilidad?	CUMPLE PARCIALMENTE	esta en proceso para la implementacion de los criterios segun la iso 27001	establecer criterios para la deciciones como por ejemplo resultados de analisis y tratamiento de riesgos, requisitos legales, la utilizacion de la imporfacion adquirida y cuales son los recursos disponibles. uan buena documentacion detallada con informacion clara y de faciel entendimiento a la hora de exponerla

5	¿Se mantiene información documentada de los puntos anteriores?	CUMPLE PARCIALMENTE	cuentan con documentacion pero muy basica de los procesos, con basios de procesos o evaluaciones de riesgos en donde no se cuenta con la documnetacion para sus analisis y progresos de abanses sobre estos temas	implemetacion de normas con criterios claros, la creacion de informes y analisis de riesgos, un plan de tratamientos de riesgo normado, un correcon analisis de la delcaracion de apliczbilidad, tener claros los criterios para la aceptacion de los reisgos, y documentacion de los procedimientos llevados a cabo, al tener una buena documnetacion en la cual se mantiene actualizada se puede llevar aabo una bena gestion y ejecucion de planes ya definidos.
6.2	PLANIFICACION PARA CONSECUCION DE OBJETIVOS			
1	¿Se han establecido objetivos de la Seguridad de la Información medibles y acordes a los objetivos del negocio?	CUMPLE PARCIALMENTE	cuentas con metas convretas pero muy alejada con el tipo de rubro que mantiene la empresa	Redactar objetivos con indicadores de rendimiento que puedan ser evaluados a cordes a la exigencias y tipo de lubro tiene la empresa .
2	¿Los objetivos de la Seguridad de la Información están planificados mediante? -Asignación de responsabilidades -Cronograma de ejecución temporal -Método de evaluación	NO CUMPLE	no cuenta con con una organizacion clara como por ejemplo no cuenta con responsables a cargo, no tiene estipulado fechas de entrega o plazos, no cuentan con metodo de evaluacion	Crear planes con responsables, plazos e indicadores de seguimiento, implementacion de meodo de evaluacion.
3	¿Se han integrado los objetivos de la Seguridad de la Información en los procesos de la organización teniendo en cuenta las funciones principales dentro de la Organización?	CUMPLE PARCIALMENTE	existen objetivos pero son generales y no adaptadas a las funciones de cada funcionario	ceacion de objetivos especificos segun el area determinada con su perosnal a cargo y de ejecuncion de dichos planes como por ejemplo rea de RRHH tengan objetivos claros en la verificacion de antecedentes, acuerdos de confidencialidad firmados. finanzas aasegurar pagos a probedores con prtocolos accesos contables, etc
7	SOPORTE			
7.1	RECURSOS			

1	¿Se identifican y asignan los recursos necesarios para el SGSI?	NO CUMPLE	falta de documentacion con estadisticas reales para la evaluacion de distribucion de recursos	realizacion de analisis con datos reales y documentados para correcta evaluacion y decisiones de financiamiento tanto humano, financiero, fisico como infraestructura y tiempo
7.2	COMPETENCIA			
1	¿Se evalúa la competencia en materias de Seguridad de la Información para personas que efectúan tareas que puedan afectar a la seguridad?	NO CUMPLE	no cuenta con personal capacitado. no se tiene competencias claras para dicho proceso	identificación de competencias necesarias para el cargo, identificación de roles críticos para la seguridad de la información, evaluaciones de desempeño, disponer de capacitaciones constantes al equipo, una buena implementación de planes de mejora al personal o la sección ya determinada
2	¿Se mantiene información actualizada sobre la competencia del personal?	NO CUMPLE	no cuenta con registros actualizados del personal	creación de registros formales de competencias del personal, para así determinar actualizaciones de certificaciones o reentrenamientos del personal según sus competencias y necesidades de cada equipo
7.3	CONCIENCIACION			
1	¿El personal está involucrado y es consciente de su papel en la Seguridad de la Información?	NO CUMPLE	falta de comunicación, y de personal responsable en las áreas determinadas	definición de roles claros según el área, capacitación constante del personal y general una concientización y responsabilidad de sus labores
2	¿Existe conciencia de los daños que se pueden producir de no seguir las pautas de la Seguridad de la Información?	NO CUMPLE	no cuentan con un conocimiento de los riesgos tangible o documentado con estadísticas para la realización de concientización del personal	creación de capacitaciones con información real y actualizada sobre riesgos y consecuencias de tipo legales. creación de políticas internas donde se determine las medidas disciplinarias, determinar claramente los daños y sus consecuencias dentro de la empresa
7.4	COMUNICACION			

1	¿Se comunica la política de la Seguridad de la Información con las responsabilidades de cada uno?	NO CUMPLE	flata de comunicacion entre empleador y empleado, dejando espacios basios donde se puede mal interpretar cualquier desicion o actuar	Establecer un canal formal (intranet, correo, reuniones) para comunicar responsabilidades y notificar deficiencias.
2	¿Existe un proceso para comunicar las deficiencias o malas prácticas en la seguridad de la Información?	NO CUMPLE	no existe un canal o un proceso definido para informar sobre malas practicas	-establecer un canal oficial para dichos reportes con un formulario especifico manteniendo la confidenclidad del denunciante, generar ambientes en donde el el personal no tenga miedo al reportar errores o malas practicas. asignacion de personal capacitado para llevar un seguimiento dichos reportes. documentar todo proceso con creacion de folios o partes de seguimiento, capacitaciones al perosanl para que tenga claro que hacer ante una cituacion de este indole
7.5	INFORMACION DOCUMENTADA			
1	¿Se dispone de la documentación requerida por la norma más la requerida por la organización incluyendo? -La política de la Seguridad de la Información y el alcance del Sistema de Gestión -Los procesos principales de la seguridad de la Información -Los Documentos exigidos por la Norma ISO 27001 incluyendo registros -Los Documentos propios de Seguridad de la Información identificados por la empresa (instrucciones técnicas etc.)	CUMPLE PARCIALMENTE	cuenta con documentacion pero no actualizada, y dentro la documentacion falta de informacion solicitada	Crear un procedimiento de control documental con control de versiones, revisiones, y gestión de documentos externos. asegurar que la documentacion sea con los requirimientos de la iso 27001, que sean accesibles, auditables y con un lenguaje tecnico y a u vez falcil de entender

2	¿Existe un control documental donde se verifica? -Quien publica el documento -Quien lo autoriza y como se revisan -Formatos y Soportes de publicación -Su almacenamiento y protección	NO CUMPLE	existen documentos con poca muy poca informacion, no mantiene nombre de quien realiza los procedimientos o quien aprueba	realizacion de dcumentos prebiamente diseñados con formatos que cumplan ciertos requicitos como quein elabora dicho documento, quien lo revisa y quien lo autoriza. que los dcumentos sean entregados con un formato ya especificado como por ejemplo en pdf. o en papel pero con un formato especifico. que dentro de la planificacion o estandar de los documentos tengan una frecuencia revicion lo cual quede registro en caso de modificacion. que los documentos esten almacenado en lugares seguros con un respaldo y control de acceso.
3	¿Se controlan los documentos de origen externo?	NO CUMPLE	no existe un registro de control o de evaluacion de la informacion de los documentos externos	generar normas especificas para clasificar los documentos por prioridades. definir porcesos para la revicion. copias de respaldos actualizadas.
8	OPERACIONES			
8.1	CONTROL DE OPERACIONES			
1	¿Los procesos de seguridad de la Información están documentados para controlar que se realizan según lo planificado?	CUMPLE PARCIALMENTE	existen documentacion pero no de todos los procesos	Documentar los procedimientos operativos y realizar auditorías internas sobre su cumplimiento.
2	¿Existe un proceso para evaluar los riesgos en la Seguridad de la Información antes de realizar cambios en el Sistema de Gestión o procesos de Seguridad?	CUMPLE PARCIALMENTE	existe un proceso de prueba pero se documenta dichos proceso	establecer procedimientosformales de gestion de cambios. evaluar riesgos prebios a los cambios. documentar dichas pruebas. monoitorear cada paso al implementar dichos cambios.

3	¿Se establecen medidas y planes para mitigar los riesgos en la Seguridad de la Información ante cambios realizados?	CUMPLE PARCIALMENTE	existen planes pero poca documentacion	definir planes de tratamiento de riesgos. establecer controles especificos para mitigar riesgos. crear planes documentados y la verificación de controles. teniendo estos lograremos que cada cambio tenga un plan de mitigación de riesgos con su documentación previa demostrando evidencia de los riesgos y beneficios del cambio
4	¿Se identifican y controlan los procesos externalizados en cuanto a los riesgos para la Seguridad de la Información?	CUMPLE PARCIALMENTE	se identifican pero no existen planes de acción ante los riesgos	recomendamos la identificación de todos los procesos externalizados más relevantes. evaluar los riesgos asociados. establecer controles y requisitos de seguridad en contratos. control de monitoreo a los procesos y documentarlos.
8.2	ANÁLISIS DE RIESGO DE LA SEGURIDAD DE LA INFORMACIÓN			
1	¿Se ha establecido un proceso documentado de análisis y evaluación de riesgos para la Seguridad de la Información donde se identifique? -El propietario del riesgo -La importancia del riesgo o nivel de impacto -La probabilidad de ocurrencia	NO CUMPLE	no existe documentación de proceso estándar de análisis y evaluación de riesgos	tener procedimientos documentados. establecer metodologías coherentes. asignaciones de propietarios de riesgos. registrar los riesgos evaluados.
8.3	TRATAMIENTOS DE RIESGOS DE LA SEGURIDAD DE LA INFORMACIÓN			
1	¿Se ha implementado un plan de tratamiento de riesgos dónde? -Los propietarios del riesgo están informados y han aprobado el plan -Se documentan los resultados	NO CUMPLE	no se han implementado planes de tratamiento de riesgos	la creación de planes de tratamiento de riesgos formales y estandarizados. la correcta involucración del propietario del riesgo. la correcta documentación y la constante actualización de la declaración de aplicabilidad
2	¿Se identifican todos los controles necesarios para mitigar el riesgo justificando su aplicación?	NO CUMPLE	no se identifican por consecuencia no existen planes de mitigación	recomendamos identificar los controles de riesgos. justificar su aplicación excluyendo dependiendo del análisis previo

3	¿Se documenta el nivel de aplicación de todos los controles a aplicar?	CUMPLE PARCIALMENTE	en procesos de documentacion	implementar lclaracion de aplicabilidad. definicion de los criterios para cada clasificacion. contante actualizacion de las evidencias encontradas.
---	--	---------------------	------------------------------	---

A9	CONTROL DE ACCESO		MOTIVO	ACCION CORRECTIVA
A9.1	REQUISITOS GENERALES PARA EL CONTROL DE ACCESO			
1	¿Existe una política para definir los controles de acceso a la información que tengan en cuenta el acceso selectivo a la información según las necesidades de cada actividad o puesto de trabajo?	CUMPLE	La información es enviada en base al puesto y ubicación de las tiendas y departamentos, además que separadas por departamentos	-Mejor capacitación ya que si bien esto se hace manual un error manual puede enviar la información a otra área
2	¿Se establecen accesos limitados a los recursos y necesidades de red según perfiles determinados?	CUMPLE	Se manejan distintos tipos de redes en base al cargo y área que lo usará	-Los sistemas son algo lentos y arcaicos
A9.2	ACCESOS DE USUARIOS			
1	¿Existen procesos formales de registros de usuarios?	CUMPLE PARCIALMENTE	-Los registros de usuarios no quedan grabadas sus acciones además de que es muy tardado a la hora de entregar el perfil al usuario y estos vienen con errores en los datos personales	-Optimizar la creación de usuarios a medida de que estos ingresan a la empresa y validar la información personal de los usuarios así como sus datos
2	¿Existen procesos formales para asignación de perfiles de acceso?	CUMPLE	-Cada empleado y área tiene su perfil y acceso a datos según su cargo	-Mejorar la velocidad en la que se revocan o cambian permisos en caso de que cambie de cargo el empleado
3	¿Se define un proceso específico para la asignación y autorización de permisos especiales de administración de accesos?	CUMPLE PARCIALMENTE	-Cada empleado tiene permisos en base a su función sin embargo al cambiar de función o de área este todavía puede acceder a la información del área anterior, así como los equipos no se formatean quedan sus credenciales ligadas aunque estos los use otra persona	-tener mejor control de los permisos y revocarlos al momento de que se efectúe un cambio de cargo y formatear y condicionar los equipos cada que se le entregue a una nueva persona

4	¿Se ha establecido una política específica para el manejo de información clasificada como secreta ? en cuanto a: -Autenticación -Compromisos	CUMPLE PARCIALMENTE	-La información clasificada se maneja con cuidado y los accesos son enviados al momento que se desee compartir sin embargo no hay control de registros ni de autenticación o tiempos de vencimiento del acceso	- se debe implementar control de registros de autenticación más allá de el correo así como agregar tiempo límite de acceso para que no puedan entrar personas no autorizadas que usen el computador
5	¿Se establecen periodos concretos para renovación de permisos de acceso?	CUMPLE PARCIALMENTE	si se establecen sin embargo los periodos son muy largos aproximadamente de 1 o 2 meses, se hacen algunas excepciones en caso que sea urgente pero igual es tardado atrasando el trabajo	-Reducir los tiempos de renovación de permisos para tener mayor control de como se gestionan los datos de la empresa
6	¿Existen un proceso definido para la revocación de permisos cuando se finalice una actividad, puesto de trabajo o cese de contratos?	CUMPLE PARCIALMENTE	-Si se maneja sin embargo el proceso de desvinculación tarda aproximadamente de 1 a 2 días, tiempo en el cual las personas aun tienen acceso a esa información	-Dar prioridad a la revocación de permisos para no comprometer la información a que sea robada o alterada después de que se le de cese de contrato al usuario
A9.3	RESPONSABILIDADES DE LOS USUARIOS			

1	¿Se establecen normas para la creación y salvaguarda de contraseñas de acceso?	CUMPLE PARCIALMENTE	-el proceso de creacion si bien pide ciertos requisitos estos son completamente seguros ya que solo pide que no sea la misma a la anterior, ademas que se comete un error gravisimo en cuanto a la salvaguarda ya que los empleados de cargo "administrador de tienda" estan obligados a mantener todas sus contraseñas anotadas en un papel y pegarlo en el computador	-Aumentar los requisitos de las contraseñas para tener un revestimiento mas seguro en la encriptacion de contraseñas y cambiar el sistema de marcacion, visualizacion de pedidos y avisos a central de monitoreo para que los empleados comunes no requieran acceso al computador del aministrador
A9.4	Control de acceso a sistemas y aplicaciones			
1	¿Se establecen niveles y perfiles específicos de acceso para los sistemas de Información de forma que se restrinja la información a la actividad específica a desarrollar?	CUMPLE PARCIALMENTE	-Si bien cada cargo tiene funciones y niveles diferentes la informacion se comparte solo a los cargos que deben desarrollarla, sin embargo hay una falta de capacitacion al personal ya que estos hablan abiertamente de sus proyectos y funciones que desarrollan	- Capacitar a los empleados de que toda informacion referente a su cargo no debe ser compartida con otras areas sin autorizacion de los respectivos superiores
2	¿Se han implementado procesos de acceso seguro para el inicio de sesión considerando limitaciones de intentos de acceso, controlando la información en pantalla etc.?	CUMPLE	-Hay limite de acesos con un maximo de 3 intentos en los portales de empleados, la informacion en pantalla es muy breve, sin embargo se debe mejorar el acceso a los computadores	-los accesos a computadores no deben tener la imagen del empleado a cargo como foto de perfil y limitar los intentos en caso de contraseña erronea

3	¿Se establecen medidas para controlar el establecimiento de contraseñas seguras?	CUMPLE	Las contraseñas piden un minimo y maximo de caracteres y valores para ser encriptadas de manera eficientes, cada 1 mes se pide cambio de contraseña	- mejorar la forma en que los empleados guardan dichas contraseñas
4	¿Se controla la capacitación y perfil de las personas que tienen permisos de administración con perfiles bajos de Seguridad?	CUMPLE PARCIALMENTE	-La capacitacion es muy basica y ambigua dejando lugar a errores, como pishing e ingenieria social	-se debe reforzar las capacitacione sy los riesgos que comprometer la informacion pueden causar
5	¿Se restringe el acceso a códigos fuente de programas y se controla cualquier tipo de cambio a realizar?	NO CUMPLE	-Existe una gran falta de seguridad en cuanto acceso a los equipos y programas como su manipulacion y codigo fuente, los sistemas POS de caja son facilmente modificables y manipulados por los trabajadores asi como los equipos no tienen proteccion de hardware	-Optimizar el sistemas de los POS para que su uso sea solo el de venta y no poder manipular las demas funciones asi como poner medidas de seguridad como carcasas o varillas para impedir el uso de sus puertos usb
A10	CRIPTOGRAFIA			
A10.1	CONTROL CRIPTOGRAFICO			
1	¿Existe una política para el establecimiento u yo de controles criptográficos?	CUMPLE PARCIALMENTE	-Para crear contraseñas se pide un minimo y un maximo de caracteres asi como estas tienen un tiempo de vida, se solicita una clave alfanumerica sin embarco estas no piden por obligacion caracteres especiales, ni parecerse a las ultimas 3	-Si bien las contraseñas cumplen con buena encriptacion se debe reforzar los requerimientos a los usuarios de mayusculas, caracteres especiales y simbolos

2	¿Existe un control del ciclo de vida de las claves criptográficas?	CUMPLE	-Existe un ciclo de vida de 1 mes de las contraseñas	-Esta practica esta bien ejecutada
A11	SEGURIDAD FISICA Y DEL ENTORNO			
A.11.1	AREAS DE SEGURIDAD			
1	¿Se establecen perímetros de seguridad física donde sea necesario con barreras de acceso?	NO CUMPLE	-Las zonas de cables y servidores estan compartidas con las oficinas y no hay barrera de seguridad mas alla de una puerta sin llave, si bien estan en unos case que los protege del ambiente y suciedad, no lo hace de terceros	-se deben reubicar los servidores y cableados importantes asi como reforzar su seguridad poniendo una cubierta que no sea de vidrio para que no lo puedan romper, y estar con llaves o barrotes de seguridad
2	¿Existen controles de acceso a personas autorizadas en áreas restringidas?	CUMPLE PARCIALMENTE	-Los mismos trabajadores del area se encargan de matener afuera personas ajenas a la empresa sin embargo personas de otro departamentos y areas de la misma empresa pueden entrar	-Tomar medidas para que las personas no autorizadas no puedan entrar ya sea como torniquetes, id de acceso o entrar con supervision para evitar robo de datos o activos
3	¿Se establecen medidas de seguridad para zonas de oficinas para proteger la información de pantallas etc. en áreas de accesibles a personal externo?	NO CUMPLE	-Cualquier persona que entre en el area de oficinas puede ver lo que hay en los ordenadores, claves, proveedores, informacion confidencial de los empleados o del empleador incluso sin entrar en la oficina ya que el computador apunta a la puerta	-Cambiar la ubicacion del computador, agrgar un bloqueo de pantalla por inactividad, si se abandona el area cerrar la oficina, reforzar normas de seguridad al personal

4	¿Se controla o supervisa la actividad de personal que accede a áreas seguras?	NO CUMPLE	-El personal puede acceder a cualquier area sin problema, no hay supervision de superiores o camaras de seguridad, y las pocas que hay no son monitoreadas con frecuencia a no ser en caso de emergencia	-Añadir control de acceso, las medidas como camaras, guardias, capacitacion y tener un registro de las personas que acceden a estas areas
5	¿Se controlan las áreas de Carga y descarga con procedimientos de control de mercancías entregadas etc.?	NO CUMPLE	-No hay control en las areas de carga o descarga mas que el personal que las realiza y el que las recibe para asegurar que este todo al día y no falten productos	-supervision, camaras asi como personal mas capacitado para hacer busquedas minuciosas como fechas de vencimiento
A11.2	SEGURIDAD DE LOS EQUIPOS			
1	¿Se protegen los equipos tanto del medioambiente como de accesos no autorizados?	NO CUMPLE	-No hay proteccion contra no autorizados ni contra el medio ambiente, los equipos y cables estan en la interperie al alcance de todos	-Reforsar las medidas de seguridad con mejores cerraduras para evitar los accesos asi como pantallas de acrilico para que no tengan acceso a los equipos que deben permanecer afuera y colocar un case para rpotegerlos del ambiente
2	¿Se protegen los equipos contra fallos de suministro de energía?	NO CUMPLE	-No hay proteccion y se encuentran mas de un reporte por averias debido a bajones y apagones de luz	-Tener un protector de corrieente para los bajones o apagones de luz, y buscar una fuente para que los equipos de refrigeracion no dañen los activos de venta como comida

3	¿Existen protecciones para los cableados de energía y de datos?	NO CUMPLE	-Los cables se encuentran en la interperie y doblados, muestran daños y las gomas que los protege esta vencida y se rompen al doblarlos, los cables electricos estan expuestos en algunas zonas lo cual hay riesgo de electrocucion	-Arreglar urgentemente el cableado electrico y cambiar los cables de datos asi como ordenarlos y comprarles una cubierta o canaleta
4	¿Se planifican y realizan tareas de mantenimiento sobre los equipos?	CUMPLE PARCIALMENTE	-Se realizan funciones de matencion programadas sin embargo en caso de que estos tengan un error o malfuncion solo se reporta mas no se ven arreglos a menos que sean urgentes	-Realizar mantenciones con mas frecuencia y remplazar las piezas dañadas al encontrarse la falla no solo cuando sea urgente
5	¿Se controlan y autorizan la salida de equipos, aplicaciones etc. Que puedan contener información?	CUMPLE PARCIALMENTE	-si bien hay control de cuando salen los equipos de su respectiva area la autorizacion es vaga y solo reportada por correo, no se lleva registros de que hace esa persona con los equipos o aplicaciones	-Tener mejor conytol de cuando un dispositivo sale y estos pasar por revisiones o llevar un registro de lo que se hizo en caso que este sea un computador
6	¿Se consideran medidas de protección específicas para equipos que se utilicen fuera de las instalaciones de la propia empresa?	CUMPLE PARCIALMENTE	-No se cumplen mas alla de los mismos que estos tengan ya que solo aplica para los portatiles autorizados los cuales e encuentran en norma, pero estos pueden ser usados, sin embargo ocurren fotos desde telefonos y trabajo desde casa el cual esta prohibido	-reforzar las capacitaciones y buscar una manera de evitar que se muevan los dispositivos de su area designada

7	¿Se establecen protocolos para proteger o eliminar información de equipos que causan baja o van a ser reutilizados?	NO CUMPLE	-no se formatean ni se toman medidas, los equipos solo son dados de baja y almacenados para repuestos, en caso que se reacondicione para otro departamento estos aun contienen datos debido a politicas de no formatear por parte de falabella	-Formatear desde cero y hacer revision del equipomantes de ser entregado a otra area o desechado
8	¿Se establecen normas para proteger la información de equipos cuando los usuarios abandonan el puesto de trabajo?	NO CUMPLE	-no existen normas, al contrario se exige que los equipos esten desbloqueados en todo momento este o no este la persona	-Cambiar las normativas de que los equipos deben bloquearse o apagarse en caso de abandonar el puesto, y las contraseñas NO deben ir pegadas al equipo
9	¿Se establecen reglas de comportamiento para abandonos momentáneos o temporales del puesto de trabajo?	NO CUMPLE	-Las personas abandonan sus puestos en cualquier momento sin justificativo o aviso desde cortos a largos periodos, no hay normas	-Reforzar el no dejar los equipos solos asi como aplicar llamados de atencion o amonestaciones en caso de que se de un abandono por motivos ajenos a necesidades basicas o emergencias
A12	SEGURIDAD EN LAS OPERACIONES			
A12.1	PROCEDIMIENTOS Y RESPONSABILIDADES			
1	¿Se documentan los procedimientos y se establecen responsabilidades?	CUMPLE PARCIALMENTE	-Se establecen las responsabilidades pero hay falta de documentacion	-Se debe llevar un registro y documentar los roles de cada persona
2	¿Se controla que la información sobre procedimientos se mantenga actualizada?	NO CUMPLE	-No se actualiza la informacion de procesos habiendo una falta grave de documentacion	-Reforzar documentacion de los procedimientos y que estas se mantengan al dia

3	¿Se dispone de un procedimiento para evaluar el impacto en la seguridad de la información ante cambios en los procedimientos?	CUMPLE PARCIALMENTE	-se lleva a cabo las evaluaciones pero son muy ambiguas dejando lugar a exploits o fallas	-examinar con mas paciencia y de mejor manera la integridad y seguridad de la informacion
4	¿Se controla el uso de los recursos en cuanto al rendimiento y capacidad de los sistemas?	NO CUMPLE	-No se examina ni se toma en cuenta causando que los equipos se encuentren saturados con codigo espagueti, funciones mal optimizadas y constantes crasheos	-optimizar los equipos, y el consumo de recursos asi como trabajar en base a la capacidad de los equipos
5	¿Los entornos de desarrollo y pruebas están convenientemente separados de los entornos de producción?	NO CUMPLE	-Solo hay 1 equipo de prueba y los errores y fallas se prueban en las mismas areas de produccion al salir los cambios	-tener mas equipos de prueba y reforzar las pruebas, enviarlas a produccion solo cuando funcionen de manera optima
A12.2	PROTECCIÓN CONTRA SOFTWARE MALICIOSO			
1	¿Existen sistemas de detección para Software malicioso o malware?	CUMPLE PARCIALMENTE	-Solo se cuenta con capacitacion de los empleados y el windows defender, los usuarios pueden descargar y ejecutar lo que les plazca	-reforzar los antivirus, bloquear los puertos usb, y capacitar mejor a los empleados
A12.3	COPIAS DE SEGURIDAD			
1	¿Se ha establecido un sistema de copias de seguridad acordes con las necesidades de la información y de los sistemas?	CUMPLE PARCIALMENTE	-solo las areas mas urgente cuentan con estos, habiendo mucha informacion perdida	-llevar respaldo de la informacion y tener copias almacenadas de manera local de las bases de datos de empleados, certificados y antecedentes
A12.4	REGISTRO Y SUPERVISIÓN			

1	¿Se realiza un registro de eventos? -Intentos de acceso fallidos/exitosos -Desconexiones del sistema -Alertas de fallos Etc.	CUMPLE PARCIALMENTE	-Solo hay registros de cuando hay multiples intentos de accesos	-se debe tener mejor control de los registros para poder llevar un historial de fallas o de intentos de ingresos
2	¿Se ha establecido un sistema de protección para los registros mediante segregación de tareas o copias de seguridad?	CUMPLE PARCIALMENTE	Existe segregacion de tareas mas no registros	se deben implementar sistema de registros para poder analizar quien hizo modificaciones
3	¿Se protege convenientemente y de forma específica los accesos o los de los administradores?	NO CUMPLE	-No hay proteccion de los accesos ya que en los departamentos no hay gestion o permisos de admis son externos de la empresa	-la empresa deberia contar con al menos una persona que posea los permisos mas alla de recursos humanos
4	¿Existe un control de sincronización de los distintos sistemas?	CUMPLE PARCIALMENTE	-la sincronizacion que se haya en la nube es muy poco segura y mal optimizada asi como arcaica	-se debe mejorar la intefaz de usuario, optimizar y reforzar la seguridad asi como los tiempos de carga
A12.5	CONTROL DE SOFTWARE			
1	¿Las instalaciones de nuevas aplicaciones SW o modificaciones son verificadas en entornos de prueba y existen protocolos de seguridad para su instalación?	NO CUMPLE	no existen protocolos de seguridad para la instalacion de programas	se debe buscar un entorno de pruebas dentro de la empresa y buscar protocolos de seguridad a los cuales acoplarse
A12.6	VULNERABILIDAD TECNICA			
1	¿Se establecen métodos de control para vulnerabilidades técnicas "hacking ético" etc.?	NO CUMPLE	no cuenta con departamento encargado de hacer hacking ético	se debe contratar una persona encargada de buscarlo para poder probar las vulnerabilidades y posibles filtraciones de datos
2	¿Se establecen medidas restrictivas para la instalación de Software en cuanto a personal autorizado evitando las instalaciones por parte de usuarios finales?	NO CUMPLE	- los usuarios y empleados pueden instalar lo que deseen	restringir instalaciones y bloquear puertos USB

A12.7	AUDITORIAS DE SISTEMA DE INFORMACION			
1	¿Existen mecanismos de auditorías de medidas de seguridad de los sistemas?	CUMPLE PARCIALMENTE	-las auditorias se encargan de ver que los equipos sigan aun con sus protocolos de seguridad sin embargo no buscan mejorarlos o buscar filtraciones	la auditoria se debe hacer completa y examinar a fondo para buscar mejoras constantes, no solo verificar que los rpotocolos antiguos existan
2	¿Se establecen protocolos específicos para desarrollo de auditorías Software considerando su impacto en los sistemas?	CUMPLE PARCIALMENTE	-existe protocolo pero es muy ambiguo ya que dicho protocolo es por parte de la empresa dueña de la cadena la cual no conoce muy bien como opera esta	- se debe capacitar a las personas que desarrollan el software y realiza la auditoria para qie la revision sea mas exhaustiva

A13	SEGURIDAD DE LAS COMUNICACIONES		
A13.1	SEGURIDAD DE LAS REDES		
1	¿En el entorno de red se gestiona la protección de los sistemas mediante controles de red y de elementos conectados?	CUMPLE PARCIALMENTE	Se deben fortalecer los controles en dispositivos conectados y monitoreo activo de la red.
2	¿Se establecen condiciones de seguridad en los servicios de red tanto propios como subcontratados?	CUMPLE PARCIALMENTE	Necesario formalizar los niveles de servicio y aplicar controles a proveedores.
3	¿Existe separación o segregación de redes tomando en cuenta condiciones de seguridad y clasificación de activos?	CUMPLE	Buen manejo de redes segmentadas según clasificación de activos.
A13.2	INTERCAMBIO DE INFORMACION		
1	¿Se establecen políticas y procedimientos para proteger la información en los intercambios?	CUMPLE PARCIALMENTE	Hace falta estandarización y difusión entre los usuarios.
2	¿Se delimitan y establecen acuerdos de responsabilidad en intercambios de información con otras entidades?	CUMPLE PARCIALMENTE	Requiere formalización documental más robusta.
3	¿Se establecen normas o criterios de seguridad en mensajería electrónica?	CUMPLE PARCIALMENTE	Necesario aplicar cifrado y control de acceso en canales de comunicación.
4	¿Se establecen acuerdos de confidencialidad antes de realizar intercambios de información con otras entidades?	CUMPLE	Existe una cultura de confidencialidad contractual adecuada.
A14	ADQUISICION, DESARROLLO Y MANTENIMIENTO DE SISTEMAS DE INFORMACION		
A14.1	INTERCAMBIO DE INFORMACION		
1	¿Se definen y documentan los requisitos de Seguridad de la Información para los nuevos sistemas de Información?	CUMPLE PARCIALMENTE	Falta sistematización en la documentación de requisitos.
2	¿Se especifican los requisitos de Seguridad de la información en el diseño de nuevos sistemas?	CUMPLE PARCIALMENTE	Necesario integrar la seguridad desde las etapas iniciales del desarrollo.
3	¿Se consideran requisitos de seguridad específicos para accesos externos o de redes públicas a los sistemas de información?	CUMPLE PARCIALMENTE	Requiere mayor control en conexiones desde redes públicas.
4	¿Se establecen medidas de protección para transacciones Online?	CUMPLE	Cumple adecuadamente
A14.2	SEGURIDAD DE LOS PROCESOS DE SOPORTE		
1	¿Se establecen procedimientos que garanticen el desarrollo seguro del Software?	CUMPLE PARCIALMENTE	No todos los proyectos aplican metodologías seguras de desarrollo
2	¿Se gestiona el control de cambios en relación al impacto que puedan tener en los sistemas?	CUMPLE	Procesos estandarizados y con trazabilidad.

3	¿Se establecen procedimientos de revisión después de efectuar cambios o actualizaciones?	CUMPLE	Documentación y revisión activa de cambios.
4	¿Se establecen procesos formales para cambios en versiones o nuevas funcionalidades para Software de terceros?	CUMPLE	Cumple adecuadamente
5	¿Se definen políticas de Seguridad de la Información en procesos de ingeniería de Sistemas?	CUMPLE PARCIALMENTE	Necesario reforzar políticas internas específicas para desarrolladores.
6	¿Se realiza una evaluación de riesgos para herramientas de desarrollo de Software?	CUMPLE	Uso adecuado de herramientas y control de riesgos.
7	¿Se acuerdan los requisitos de seguridad de la Información para Software desarrollado por terceros?	CUMPLE	Existen acuerdos de seguridad previos al desarrollo.
8	¿Se realizan pruebas funcionales de seguridad de los sistemas antes de su fase de producción?	CUMPLE PARCIALMENTE	Se realizan, pero de forma inconsistente o superficial.
9	¿Se establecen protocolos y pruebas de aceptación de sistemas para nuevos sistemas y actualizaciones?	CUMPLE PARCIALMENTE	Faltaría establecer criterios técnicos más definidos para validación.
A14.3	DATOS DE PRUEBA		
1	¿Se utilizan datos de prueba en los ensayos o pruebas de los sistemas?	CUMPLE PARCIALMENTE	Requiere anonimización y separación de entornos de pruebas y producción.
A15	RELACION CON PROVEDORES		
A15.1	SEGURIDAD DE LA RELACION CON PROVEDORES		
1	¿Existe una política de Seguridad de la información para proveedores que acceden a activos de la información de la empresa?	CUMPLE PARCIALMENTE	Deben incluirse cláusulas explícitas en contratos y auditorías periódicas.
2	¿Se han establecido requisitos de seguridad de la información en contratos con terceros?	CUMPLE PARCIALMENTE	Se requiere especificidad y cumplimiento verificable.
3	- ¿Se fijan requisitos para extender la seguridad de la información a toda la cadena de suministro?	NO CUMPLE	No se han implementado controles extendidos a subproveedores.
A15.2	GESTION DE SERVICIOS INTERNOS		
1	¿Se controla el cumplimiento de los requisitos establecidos con proveedores externos?	CUMPLE PARCIALMENTE	Establecer indicadores y monitoreo podría ser beneficioso para la organización.
2	¿Se controlan los posibles impactos en la seguridad ante cambios de servicios de proveedores externos?	CUMPLE PARCIALMENTE	Requiere evaluación previa de riesgos en cambios de servicios.
A16	GESTION DE INCIDENTES DE SEGURIDAD DE LA INFORMACION		
A16.1	GESTION DE INCIDENTES DE SEGURIDAD DE LA INFORMACION Y MEJORAS		

1	¿Se definen responsabilidades y procedimientos para responder a los incidentes de la Seguridad de la Información?	CUMPLE PARCIALMENTE	Generar un plan de respuesta e integrarlo al personal sería una buena práctica.
2	¿Se han implementado canales adecuados para la comunicación de incidentes en la seguridad de la Información?	CUMPLE	Existen canales internos funcionales.
3	¿Se promueve y se hayan establecidos canales para comunicar o identificar puntos débiles en la Seguridad de la Información?	CUMPLE PARCIALMENTE	Promover cultura de reporte entre usuarios finales.
4	¿Se ha establecido un proceso para gestionar los incidentes en la Seguridad de la Información?	CUMPLE	Cumple adecuadamente
5	¿Existen mecanismos para dar respuesta a los eventos de la Seguridad de la Información?	CUMPLE	Equipos capacitados y con experiencia en respuesta a incidentes.
6	¿La información que proporcionada por los eventos en la Seguridad de la información son tratados para tomar medidas preventivas?	CUMPLE	Cumple adecuadamente
7	¿Existe un proceso para recopilar evidencias sobre los incidentes en la seguridad de la Información?	CUMPLE PARCIALMENTE	Se pueden mejorar los protocolos de recopilación de evidencias en caso de incidencias.

A17	GESTION DE LA CONTINUIDAD DEL NEGOCION		MOTIVO	ACCION CORRECTIVA
A17.1	CONTIUNIDAD DE LA SEGURIDAD DE LA INFORMACION			
1	¿Se ha elaborado un plan de continuidad del negocio ante incidentes de Seguridad de la Información?	CUMPLE	-Se cuenta con un plan solido, informacion y sistemas de respaldo, canales de comunicacion, plan de contingencia asignacion de roles util pero desordenada	-Reforzar la velocidad y compromiso a la hora de asignar roles
2	¿Se ha implementado las medidas de recuperación previstas en el plan de Continuidad del Negocio	CUMPLE	-Se cuenta con informacion de respaldo, red electrica de respaldo, plan de recuperacion de datos y personal capacitado para la recuperacion de datos, el sistema de red interno en caso de falla es algo arcaico y lento	-se debe optimizar y mejorar la red de respaldo
3	¿Se han verificado o probado las acciones previstas en el plan de Continuidad del Negocio?	CUMPLE PARCIALMENTE	-Las pruebas de recuperacion, simulacros se hacen seguido pero la documentacion de estas es muy ambigua	-se debe mejorar los registros y documentacion de estos para observar las debilidades del personal y los equipos
A17.2	REDUNDANCIAS			
1	¿Se ha evaluado la necesidad de redundar los activos críticos de la Información?	CUMPLE PARCIALMENTE	-los activos se tienen evaluados correctamente (servidores, base de datos, sistemas de comunicacion), pero el sistema de cluster, la disponibilidad de estos y los respaldos en tiempo real tienen mucho retraso	-Buscar la manera de que estos sean accesibles entodo momento ubicandolos en el mismo edificio, y optmizar los tiempos de los respaldos automaticos
A18	CUMPLIMIENTO			
A18.1	CUMPLIMIENTO DE LOS REQUISITOS LEGALES Y CONTRACTUALES			

1	¿Se han identificado las legislaciones aplicables sobre protección de datos personales y su cumplimiento? -LOPD -Leyes para comercio Electrónico -Transacciones Bancarias -Información Protegida -Otras propias del negocio o actividad -Ley general de Telecomunicaciones	CUMPLE PARCIALMENTE	-todo esta protegido y en orden sin embargo las transacciones entre locales y sucursales no estan documentadas afectando el inventario de las tiendas	-Documentar y dejar constancia de transferencia de activos
2	¿Existen procedimientos implementados sobre la propiedad intelectual?	CUMPLE	-Todas las licencias estan al dia	-Se debe mantener todo al dia y verificar las fechas de las licencias
3	¿Se establecen criterios para clasificación de registros y medidas de protección según niveles?	CUMPLE PARCIALMENTE	-La informacion se encuentrea debilmente protegida entre departamentos pero se limita correctamente entre personas afines a la empresa y personas ajenas a esta	-se debe reforzar y separar la informacion confidencial y delicada entre departamentos asi como separar estos departamentos
4	¿Se establecen medidas para la protección de datos personales de acuerdo con la legislación vigente?	CUMPLE	-se respetan y cumplen todas las leyes de proteccion (consentimiento, anonimato,cifrado, derecho de acceso,etc)	-seguir mejorando y reforzando los cifrados y proteccion de datos
5	¿Si se utiliza el cifrado, se establecen controles criptográficos de acuerdo a la legislación?	CUMPLE	-se respetan las normativas internacionales y nacionales asi como las politicas internas deseguridad	-seguir reforzando la encriptacion y mantenerla al dia con las politicas
A18.2	REVISION DE LA SEGURIDAD DE LA INFORMACION			
1	¿Se revisan los controles de la Seguridad de la Información por personal independiente a los responsables de implementar los controles?	CUMPLE PARCIALMENTE	-Las auditorias usualmente siempre son internas rara vez externas afectando la imparcialidad de estas	-se deben hacer auditorias externas mas seguidos asegurar la imparcialiad y eficiencia de estas

2	¿Se revisa periódicamente el cumplimiento de las políticas y controles de la Seguridad de la información?	CUMPLE	-Las políticas y controles así como su documentación se mantienen al día, se revisan y actualizan anualmente y tras cambios de gerencia	-La práctica a realizar se hace correctamente y se debe seguir ejecutando efectivamente
3	¿Se realizan evaluaciones sobre el correcto funcionamiento de las medidas técnicas de protección para la seguridad de la información?	CUMPLE	-Se realizan auditorías, simulacros y pruebas de manera correcta	-se deben realizar de manera más seguida y entornos más seguros así como buscar auditores externos